Compliance Officer: oral preparation

A practical defense pack for the 7-minute bank AI governance video and executive-board jury.

Prepared for 5DA06 · Reviewed 1 November 2026

Online reader: https://pqhhust.github.io/ai-ethics-atlas/

Project scope

Completed proposed recommendation for the supplied banking scenario, refined using the instructor's video and oral-defense guidance. The controls are proposals, not reported implementation results.

Opening statement

- My role is to identify which applications the bank can deploy, under which legal conditions. I would assess each application separately: a shared LLM does not give every use the same risk classification.
- I support a bounded internal pilot. Customer chat needs transparency and reliable escalation; fraud controls need proportionate safeguards and rapid correction. I would hold production credit assessment until we can demonstrate lawful data use, reliable validation and meaningful review.
- The vendor cannot take over the bank's responsibilities. We need clear roles, supplier controls and evidence of what the system actually does. My compromise is a staged rollout with named owners, release conditions and stop triggers.

Approximately 120 words. Rehearse for about one minute and adapt to the group's final recommendation.

Decisions to defend

Internal drafting / search · Conditional pilot

No automatic high-risk classification from using an LLM alone. Check whether the actual purpose falls into a regulated category.

- Approved data and access controls
- No unrestricted customer-data prompts or hidden employment monitoring
- AI-literacy support, source verification and escalation

AI Act · 3 · Definitions
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_3

AI Act · 4 · AI literacy
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_4

GDPR · 5 · Principles relating to processing of personal data
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_5

GDPR · 25 · Data protection by design and by default
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_25

Customer chatbot · Conditional release

AI interaction transparency plus privacy and consumer-facing reliability. Reclassify if the bot becomes part of a consequential assessment.

- Clear AI disclosure and bounded authority
- Verified knowledge sources and human escalation
- Logs, complaints and update testing

AI Act · 50 · Transparency obligations for providers and deployers of certain AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_50

GDPR · 13 · Information to be provided where personal data are collected from the data subject
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_13

GDPR · 32 · Security of processing
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_32

Consumer credit assessment · Hold production pending evidence

Annex III(5)(b), GDPR automated-decision safeguards and consumer-credit rights. The proposed hold is a governance decision, not a blanket legal ban on LLMs.

- Application-specific validation and discrimination assessment
- Lawful inputs, meaningful review and faithful explanations
- DPIA/FRIA planning, documented provider/deployer roles

AI Act · Annex III · High-risk AI systems referred to in Article 6(2)
https://ai-act-service-desk.ec.europa.eu/en/ai-act/annex-3

AI Act · 25 · Responsibilities along the AI value chain
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_25

AI Act · 27 · Fundamental rights impact assessment for high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_27

GDPR · 22 · Automated individual decision-making, including profiling
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_22

Consumer credit · 18 · Obligation to assess the creditworthiness of the consumer
https://publications.europa.eu/resource/cellar/12d92010-76c8-11ee-99ba-01aa75ed71a1.0006.03/DOC_1#art_18

Financial-fraud detection · Bounded pilot with safeguards

Excluded from Annex III(5)(b) specifically; assess the actual decision effects and any other relevant rule.

- Separate alerts from restrictions and final decisions
- Urgency-sensitive escalation, correction and review
- Monitor false positives and disproportionate effects

AI Act · Annex III · High-risk AI systems referred to in Article 6(2)
https://ai-act-service-desk.ec.europa.eu/en/ai-act/annex-3

GDPR · 22 · Automated individual decision-making, including profiling
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_22

DORA · 6 · ICT risk management framework
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_6

Workplace emotion inference · Exclude from the proposal

Article 5 prohibition has narrow medical/safety exceptions. Productivity or general monitoring is not a substitute for those conditions.

- Reject prohibited purpose
- Consider less intrusive employee support
- Consult employee representatives where required

AI Act · 5 · Prohibited AI practices
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_5

French labour law · L2312-8 · CSE: consultation / workplace technology
https://code.travail.gouv.fr/code-du-travail/l2312-8

Release gates

1. Register

Owner: Application owner + Compliance

Evidence: Purpose, affected groups, outputs and decision effects; model, data and supplier inventory.

2. Classify

Owner: Compliance + Legal + DPO

Evidence: AI Act category and role mapping; legal bases; sectoral scope; dated obligations and prohibitions.

3. Assess

Owner: Owner + technical team + Ethics + Security

Evidence: Risk register, data quality and group performance, DPIA/FRIA where applicable, alternatives and residual risks.

4. Contract and consult

Owner: Procurement + Security + DPO + HR

Evidence: Supplier terms, data access/transfers, resilience and exit; CSE process where required.

5. Validate and release

Owner: Accountable business authority with specialist sign-off

Evidence: Test results, real oversight and complaints rehearsal, operating limits, rollback and documented release decision.

6. Monitor and revise

Owner: Operations + application owner + Compliance

Evidence: Errors and complaints, drift, incidents, supplier changes, periodic review and stop/reclassification triggers.

Board evidence checklist

- What exact decision does this application influence?
- Which data and affected groups are involved?
- Is the bank a provider, deployer, controller or processor for each activity?
- Which obligation applies now, and which has a later application date?
- Can a human genuinely correct the decision?
- Can an affected person understand and contest the real reasons?
- Do supplier contracts and actual data flows match?
- Who monitors, reports incidents and can stop the use?

Seven-minute video structure

- 0:00–0:25 · The decision
- 0:25–0:50 · The technical proposal
- 0:50–1:55 · Hosting and control
- 1:55–3:30 · Credit and meaningful explanations
- 3:30–4:55 · Fraud and the burden of mistakes
- 4:55–5:40 · Governance and workers

- 5:40–6:40 · The board recommendation
- 6:40–7:00 · Buffer before the seven-minute limit

Challenge the other roles

- Technical team: Which observed evidence shows the explanation matches the actual assessment, and when should the system abstain?
- Cybersecurity team: Who can access prompts and logs, including subprocessors and foreign support staff, and can we operate if the API fails?
- Ethics officer: Which groups bear false-positive costs, and how do we turn that concern into a measurable release condition and usable remedy?
- Project manager: Who owns residual risk and what benefit justifies the remaining harm or delay?
- Supplier: Can the bank obtain the information, audit rights and change notices needed to meet its own duties?

Thirty jury drills

Rehearse an answer for about 60 seconds. Give a direct decision, its legal reason and one concrete safeguard, then address the follow-up.

O01 · What is your recommendation as Compliance Officer?

- I support a staged platform rollout with approval for each use case.
- I would allow a bounded low-risk pilot, require specific controls for customer chat and fraud, and hold production credit assessment until its evidence and review process are adequate.
- I would reject prohibited uses and keep management accountable for the deployment decision.

Follow-up: What evidence would change your recommendation?

AI Act · 6 · Classification rules for high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_6

AI Act · 25 · Responsibilities along the AI value chain
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_25

GDPR · 35 · Data protection impact assessment
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_35

O02 · Is the entire platform high-risk?

- The underlying model does not determine every application’s classification.
- I classify the intended purpose, affected people and decision effects of each system.
- Credit scoring and a general drafting assistant therefore need different assessments.

Follow-up: Can an assistant become high-risk later?

AI Act · 3 · Definitions
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_3

AI Act · 6 · Classification rules for high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_6

AI Act · Annex III · High-risk AI systems referred to in Article 6(2)
https://ai-act-service-desk.ec.europa.eu/en/ai-act/annex-3

O03 · Why is credit scoring high-risk but fraud detection different?

- Annex III(5)(b) covers natural-person creditworthiness and credit scoring.
- It expressly excludes systems used for detecting financial fraud from that entry.
- That exception does not remove GDPR, DORA or other applicable AI Act rules.

Follow-up: What if the fraud score determines access to credit?

AI Act · Annex III · High-risk AI systems referred to in Article 6(2)
https://ai-act-service-desk.ec.europa.eu/en/ai-act/annex-3

GDPR · 22 · Automated individual decision-making, including profiling
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_22

O04 · The adviser signs the decision. Why are you still concerned?

- I need meaningful judgment, not a signature.
- The adviser needs relevant information, time and authority to disagree, without incentives that make disagreement unrealistic.
- SCHUFA shows why a decisive automated score can itself matter under Article 22.

Follow-up: How would you test this in practice?

GDPR · 22 · Automated individual decision-making, including profiling
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_22

CJEU judgments · C-634/21 • 7 December 2023 · SCHUFA
https://publications.europa.eu/resource/cellar/acd82fb9-94e3-11ee-b164-01aa75ed71a1.0010.05/DOC_1

AI Act · 14 · Human oversight
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_14

AI Act · 26 · Obligations of deployers of high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_26

O05 · Does GDPR ban automated credit decisions?

- Article 22 establishes a protection against solely automated decisions with legal or similarly significant effects.
- Its exceptions have specific conditions, including necessity, legal authorisation or explicit consent, with safeguards.
- I would assess the actual workflow and the applicable exception rather than claim every scoring tool is banned.

Follow-up: Is a faster process enough to prove contractual necessity?

GDPR · 22 · Automated individual decision-making, including profiling
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_22

O06 · Why pause credit use if high-risk duties are delayed?

- The delay does not remove GDPR, existing consumer law or operational-risk obligations.
- CCD2's relevant national measures apply from 20 November 2026, within their scope.
- Our proposed hold is an evidence-based governance choice, not a claim that all LLM credit use is legally forbidden.

Follow-up: Which requirement is binding today, and which is a release condition you recommend?

AI Act · 113 · Entry into force and application
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_113

Consumer credit · 48 · Transposition
https://publications.europa.eu/resource/cellar/12d92010-76c8-11ee-99ba-01aa75ed71a1.0006.03/DOC_1#art_48

French consumer credit · Ordonnance Art. 99 · Entry into force and transitional rules
https://www.legifrance.gouv.fr/jorf/id/JORFTEXT000052184230

GDPR · 22 · Automated individual decision-making, including profiling
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_22

O07 · What exactly changes on 2 December 2027?

- The amended Article 113 schedules Chapter III Sections 1–3, except Article 6(5), for Annex III high-risk systems.
- It is too broad to say every AI Act obligation is postponed.
- I would use a provision-by-provision calendar and check transitional rules for the actual system.

Follow-up: What about chatbot transparency and existing systems?

AI Act · 113 · Entry into force and application
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_113

AI Act · 111 · AI systems already placed on the market or put into service and general-purpose AI models already placed on the marked
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_111

AI Act · 50 · Transparency obligations for providers and deployers of certain AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_50

O08 · Can we send customer data to an external API?

- Only after the relevant legal and operational checks are satisfied.

- I need purpose and data-flow mapping, lawful basis, provider roles, retention and reuse terms, security and transfer analysis.
- DORA adds third-party risk and contractual requirements; it does not itself impose a blanket API ban.

Follow-up: Would EU hosting alone satisfy you?

GDPR · 28 · Processor
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_28

GDPR · 32 · Security of processing
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_32

GDPR · 44 · General principle for transfers
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_44

DORA · 28 · General principles
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_28

DORA · 30 · Key contractual provisions
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_30

O09 · Who is responsible: the bank or the model vendor?

- Both may have responsibilities for different objects and activities.
- The vendor may be a GPAI provider; the bank may provide a downstream system and deploy it.
- Contracts support compliance, but do not automatically transfer the bank's own statutory duties.

Follow-up: When does the bank become a provider?

AI Act · 3 · Definitions
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_3

AI Act · 25 · Responsibilities along the AI value chain
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_25

AI Act · 53 · Obligations for providers of general-purpose AI models
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_53

DORA · 28 · General principles
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_28

O10 · What is the difference between a provider and a controller?

- Provider/deployer describes AI Act responsibilities for models and systems.
- Controller/processor describes who determines personal-data processing purposes and means, and who processes on behalf of another.
- I would document both mappings separately for the bank and each supplier.

Follow-up: Could the same organisation have both roles?

AI Act · 3 · Definitions
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_3

GDPR · 4 · Definitions
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_4

GDPR · 28 · Processor
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_28

O11 · Do we need a DPIA, a FRIA or both?

- I would assess the GDPR DPIA trigger for the personal-data processing.
- For the relevant high-risk credit deployment, Article 27 sets a distinct fundamental-rights assessment obligation on the applicable timetable.

- Shared evidence can reduce duplication, but one label does not automatically satisfy both.

Follow-up: What would the FRIA add beyond data security?

GDPR · 35 · Data protection impact assessment
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_35

AI Act · 27 · Fundamental rights impact assessment for high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_27

O12 · What proof would you request before release?

- A documented purpose and classification, role map and data-flow inventory.
- Validation by relevant groups, risk assessments, faithful explanations and a working human-review route.
- Supplier terms, security and resilience evidence, logging, monitoring, incident ownership and signed release conditions.

Follow-up: Which of these are legal duties and which are assurance measures?

AI Act · 9 · Risk management system
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_9

AI Act · 26 · Obligations of deployers of high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_26

GDPR · 35 · Data protection impact assessment
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_35

DORA · 30 · Key contractual provisions
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_30

O13 · Can the LLM write the explanation of a refused loan?

- It may help present verified reasons in clear language.
- The explanation must reflect the actual assessment and decision, not invent a persuasive story.
- I would require traceability to decision evidence and test whether customers can understand and challenge it.

Follow-up: Does that mean we must disclose the source code?

GDPR · 15 · Right of access by the data subject
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_15

CJEU judgments · C-203/22 • 27 February 2025 · Dun Bradstreet
https://publications.europa.eu/resource/cellar/44fa73b1-f4ef-11ef-b7db-01aa75ed71a1.0010.05/DOC_1

Consumer credit · 18 · Obligation to assess the creditworthiness of the consumer
https://publications.europa.eu/resource/cellar/12d92010-76c8-11ee-99ba-01aa75ed71a1.0006.03/DOC_1#art_18

O14 · The vendor says its algorithm is a trade secret. What then?

- Trade secrets do not justify a blanket refusal of meaningful information.
- Dun & Bradstreet requires information that enables understanding of the automated procedure, with protected interests balanced through the appropriate authority or court where needed.
- I would not approve dependence on a service the bank cannot adequately explain or review.

Follow-up: What information could be given without publishing the entire model?

GDPR · 15 · Right of access by the data subject
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_15

CJEU judgments · C-203/22 • 27 February 2025 · Dun Bradstreet
https://publications.europa.eu/resource/cellar/44fa73b1-f4ef-11ef-b7db-01aa75ed71a1.0010.05/DOC_1

O15 · Can we collect ethnicity to test discrimination?

- A bias audit and a creditworthiness input are different purposes.
- Article 4a permits exceptional processing under strict necessity and cumulative safeguards, alongside applicable data-protection rules.
- It is not permission to use sensitive attributes or social-network information as creditworthiness inputs contrary to CCD2.

Follow-up: Who accesses the audit data, and when are they deleted?

AI Act · 4a · Processing of special categories of personal data for bias detection and correction
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_4a

GDPR · 9 · Processing of special categories of personal data
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_9

Consumer credit · 18 · Obligation to assess the creditworthiness of the consumer
https://publications.europa.eu/resource/cellar/12d92010-76c8-11ee-99ba-01aa75ed71a1.0006.03/DOC_1#art_18

O16 · What does a real human-review mechanism look like?

- The reviewer sees relevant input evidence, model limitations and the actual reasons.
- They have competence, time and authority to correct or reverse the decision.
- We monitor outcomes and complaints to check whether review changes practice, not just whether a button exists.

Follow-up: Would an override-rate target create new problems?

AI Act · 14 · Human oversight
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_14

AI Act · 26 · Obligations of deployers of high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_26

GDPR · 22 · Automated individual decision-making, including profiling
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_22

O17 · Must all high-risk systems be independently certified?

- No: the conformity procedure depends on the category.
- For Annex III points 2–8, Article 43(2) specifies internal control rather than a notified-body procedure.
- Independent testing can still be valuable assurance, but I would distinguish it from a legal requirement.

Follow-up: What makes internal control credible?

AI Act · 43 · Conformity assessment
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_43

O18 · Does open-source deployment avoid the AI Act?

- No: exemptions depend on the exact object, licence and conditions.
- Article 53(2) has a limited documentation exemption for qualifying releases, with exceptions, and does not remove copyright-policy or training-summary duties.
- The bank's downstream application still needs its own assessment.

Follow-up: What evidence establishes that a release qualifies?

AI Act · 2 · Scope
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_2

AI Act · 53 · Obligations for providers of general-purpose AI models
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_53

O19 · What must a customer chatbot disclose?

- Article 50 addresses informing people that they interact with AI, subject to its conditions and exceptions.
- I would also make the bot's limits clear and offer a usable human route.
- A notice does not excuse false information, inappropriate data collection or an unauthorised decision.

Follow-up: What if the bot starts recommending a loan outcome?

AI Act · 50 · Transparency obligations for providers and deployers of certain AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_50

GDPR · 13 · Information to be provided where personal data are collected from the data subject
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_13

O20 · Can we infer employee emotions to assess stress or performance?

- Workplace emotion inference is prohibited by Article 5 subject to its narrow medical or safety exception.
- I would examine the actual purpose and conditions, not accept a relabelled productivity tool.
- For this project, I recommend excluding the feature and considering less intrusive support.

Follow-up: Can employee consent rescue a prohibited use?

AI Act · 5 · Prohibited AI practices
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_5

O21 · Must the CSE approve the platform?

- The applicable French regime requires information and consultation on relevant technology and work changes.
- Consultation must occur at the required stage before the decision; it is not simply an announcement.
- I would not describe this as a universal veto or assume the same rules apply to every employer.

Follow-up: What would you give the CSE before consultation?

French labour law · L2312-8 · CSE: consultation / workplace technology
https://code.travail.gouv.fr/code-du-travail/l2312-8

French labour law · L2312-14 · CSE: consultation / workplace technology
https://code.travail.gouv.fr/code-du-travail/l2312-14

French labour law · L2312-38 · CSE: consultation / workplace technology
https://code.travail.gouv.fr/code-du-travail/l2312-38

O22 · How do we remain agile without reviewing every prompt?

- Approve bounded use cases and control who can release applications.
- Re-review material changes to purpose, data, model, tools, supplier or decision effects.
- Use proportionate controls for ordinary drafting and stronger gates for consequential decisions.

Follow-up: Which change would immediately stop an approved pilot?

AI Act · 25 · Responsibilities along the AI value chain
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_25

AI Act · 9 · Risk management system
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_9

GDPR · 25 · Data protection by design and by default
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_25

O23 · A fraud detector needs immediate action. Must a person approve every alert?

- Not every alert has the same legal effect or urgency.

- I would distinguish alerts, temporary holds and lasting restrictions, then assess necessity, proportionality and applicable automated-decision rules.
- Urgent controls need an effective review, correction and escalation path appropriate to the actual workflow.

Follow-up: How do you monitor harm from false positives?

GDPR · 22 · Automated individual decision-making, including profiling
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_22

DORA · 6 · ICT risk management framework
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_6

AI Act · Annex III · High-risk AI systems referred to in Article 6(2)
https://ai-act-service-desk.ec.europa.eu/en/ai-act/annex-3

O24 · What happens when the vendor changes its model?

- The contract and operating process should require usable change information.
- We assess whether behaviour, purpose, compliance or security assumptions are affected and revalidate as needed.
- We need a rollback or fallback option rather than uncontrolled silent upgrades.

Follow-up: Would a model-version change always be a substantial modification?

AI Act · 25 · Responsibilities along the AI value chain
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_25

AI Act · 43 · Conformity assessment
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_43

DORA · 30 · Key contractual provisions
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_30

O25 · Can we eliminate all risk?

- No, but we can identify unacceptable uses and define justified limits for permitted ones.
- I would make residual risks, evidence gaps and responsibility explicit.
- Management receives a documented decision with monitoring and stop conditions, not a promise of zero harm.

Follow-up: Which residual risk would you refuse to accept?

AI Act · 9 · Risk management system
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_9

DORA · 5 · Governance and organisation
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_5

O26 · Which authority should we contact after an incident?

- First identify the incident and the reporting regimes that it triggers.
- A personal-data breach, a major ICT incident and an AI serious incident have different triggers and routes.
- Use the DPO, security and compliance incident process to assess each duty and deadline without assuming one report replaces all others.

Follow-up: What is the GDPR notification rule?

GDPR · 33 · Notification of a personal data breach to the supervisory authority
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_33

GDPR · 34 · Communication of a personal data breach to the data subject
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_34

DORA · 19 · Reporting of major ICT-related incidents and voluntary notification of significant cyber threats
https://publications.europa.eu/resource/cellar/0caf473a-85bd-11ed-9887-01aa75ed71a1.0006.03/DOC_1#art_19

AI Act · 73 · Reporting of serious incidents
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_73

O27 · How is your role different from the ethics officer's?

- My primary role in this exercise is AI Act classification and adequacy of legal safeguards.
- I also coordinate overlapping legal requirements with the relevant specialists.
- The ethics officer can challenge the legitimacy and distribution of harms even where a use is legally permissible; we need both analyses.

Follow-up: Could you support a lawful decision not to deploy?

AI Act · 6 · Classification rules for high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_6

AI Act · 27 · Fundamental rights impact assessment for high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_27

O28 · What compromise do you propose to the technical team?

- Allow a bounded pilot with approved data and no autonomous consequential decisions.
- Agree in advance on the evidence needed for expansion and on who can stop the pilot.
- This gives the technical team a testable route forward while preserving the stricter conditions for credit deployment.

Follow-up: What if those conditions make the business case unattractive?

AI Act · 9 · Risk management system
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_9

GDPR · 25 · Data protection by design and by default
https://publications.europa.eu/resource/cellar/3e485e15-11bd-11e6-ba9a-01aa75ed71a1.0006.03/DOC_1#art_25

O29 · Does the bank need to guarantee that everyone becomes an AI expert?

- The amended Article 4 requires measures supporting AI literacy in context.
- It does not require guaranteeing a specific literacy level for each individual.
- For high-risk oversight roles, competence, training, authority and support remain concrete requirements under Article 26(2).

Follow-up: How would training differ for a developer and a customer adviser?

AI Act · 4 · AI literacy
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_4

AI Act · 26 · Obligations of deployers of high-risk AI systems
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_26

O30 · What if the jury asks for a legal point you cannot remember?

- I would state the issue and the rule I can support, without inventing an article or deadline.
- I would identify the exact fact or provision needing verification.
- Then I would give a conditional recommendation explaining what changes under each answer.

Follow-up: Can you still make a decision with incomplete evidence?

AI Act · 113 · Entry into force and application
https://publications.europa.eu/resource/cellar/b1730fb2-8f1c-11f1-9262-01aa75ed71a1.0001.03/DOC_1#art_113

Final rehearsal

- Deliver the opening without reading it.
- Have another person choose five random questions and challenge your proposed safeguard.
- Explain one trade-off for each application: delay, cost, service access, privacy or residual harm.
- Check that every promised safeguard has an owner, evidence requirement and stop condition.
- Use the exact legal scope and dates in the reader when the jury asks a timing question.